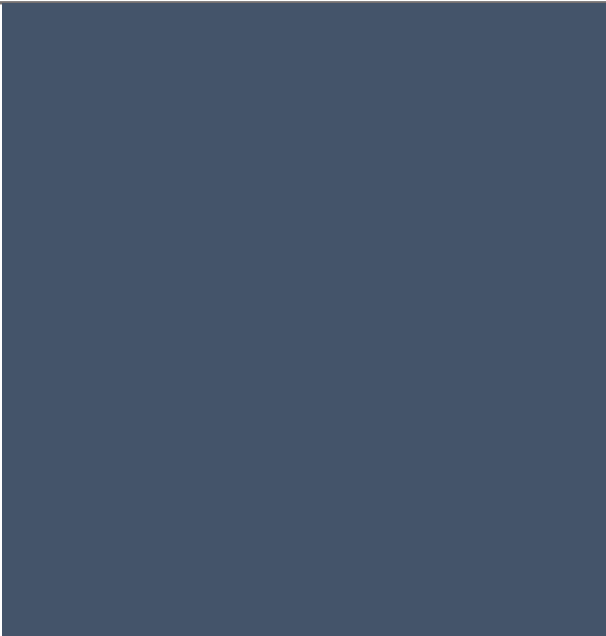




SEGG-U1-P2B - SQL Injection en ASP.NET Core

Universidad Tecnológica de
Queretaro

Diego Jesus Reyes Rebolledo 2024171017

En esta práctica se implementó una funcionalidad vulnerable a SQL Injection dentro de la aplicación local VulnerableApp.

La vulnerabilidad se encuentra en el archivo SearchController.cs, específicamente en el método Index, donde se construye una consulta SQL mediante concatenación directa del valor ingresado por el usuario.

Código vulnerable:

```
string query = "SELECT * FROM Users WHERE Username LIKE '%" + search + "%'";  
var users = _db.Users.FromSqlRaw(query).ToList();
```

El problema ocurre porque el parámetro search se inserta directamente dentro de la consulta SQL sin validación ni parametrización. Esto permite alterar la lógica original de la consulta.

Al realizar una búsqueda normal como admin, la consulta generada es:

```
SELECT * FROM Users WHERE Username LIKE '%admin%'
```

Esta consulta devuelve únicamente el usuario que coincide con la búsqueda.

Sin embargo, al ingresar una cadena manipulada como:

```
' OR 1=1 --
```

la consulta resultante puede interpretarse como:

```
SELECT * FROM Users WHERE Username LIKE '%' OR 1=1 --%'
```

La condición OR 1=1 siempre es verdadera, por lo que la base de datos devuelve todos los registros de la tabla Users. Esto representa una exposición de información debido a una consulta SQL no parametrizada.

Clasificación del hallazgo:

CWE: CWE-89

OWASP: Injection

Impacto: Exposición de datos por consulta no parametrizada

Ubicación: SearchController.Index

Conclusión:

La práctica demuestra el riesgo de construir consultas SQL mediante concatenación de cadenas. Para mitigar esta vulnerabilidad se deben usar consultas parametrizadas o mecanismos seguros de Entity Framework Core.